

ATTACK SURFACE & SAAS DISCOVERY REPORT · MERIDIANHOLDINGS.EXAMPLE

meridianholdings.example

Prepared for meridianholdings.example · 10 Jun 2026

This report assesses meridianholdings.example from the outside: what an attacker can learn from public DNS, certificates and routing data, and how well the domain is defended against it.

FOR BUSINESS READERS

Where you stand, the risks that matter, and the few changes that reduce them most.

FOR TECHNICAL READERS

The evidence behind each finding, the exact records we saw, and the fix for every gap.

OUTSIDE LOOKING IN

Which platforms you use, and how heavily attackers imitate them. This is platform-wide: the same for every customer of that platform.

YOUR DEFENSES

Your email, domain, subdomain, hosting and web settings. These are specific to you, and every gap here is yours to fix.



Critical

Risk score
85/100

higher is more
exposed

WHAT WE FOUND

OUTSIDE LOOKING IN Your DNS shows 0 platforms attackers commonly imitate. The most imitated is **Microsoft 365**: 41 critical lookalike domains in 30 days, across the internet. These are campaigns against the platform, not against you. Section 02 has the detail; section 06 lists your platforms.

EMAIL

Needs work

No DMARC and SPF: your domain can be spoofed in email.

Section 03

DOMAIN AND DNS

Adequate

Registration protected; DNSSEC and CAA not in place.

Section 03

SUBDOMAINS

None observed

No subdomains seen in certificate logs.

Section 07

HOSTING AND NETWORK

Needs review

AS64500, RU. Range reputation: high (whole network).

WEB AND CERTIFICATES

Not assessed

The HTTPS certificate was not checked.

Section 03

WHAT TO DO FIRST

- 1. RPKI state INVALID — route hijack exposure.** Work with the hosting/network provider to publish a correct ROA for the prefix.
CRITICAL
- 2. DMARC enforcement.** Publish DMARC record at _dmarc.meridianholdings.example starting with p=none for reporting. Increasingly required by Google, Yahoo, Microsoft, Apple, and Comcast for bulk-sender deliverability. **HIGH**
- 3. SPF strict mode.** Publish SPF TXT record with -all and all legitimate senders included. **HIGH**

The full sequence, with effort and ownership, is in section 09.

Scope: this assessment covers only what is visible from public DNS and certificate transparency at a point in time. It does not cover endpoint security, network segmentation, identity and access management, patch posture, or physical security — all of which a full underwriting assessment also weighs.

— A GUIDED TOUR

Mapping your attack surface, in 11 sections.

This report maps your attack surface and gives you a roadmap to reduce it. Every section is **Context**, **Findings** or **Action**. Read it in order, or take page 1, sections 02 and 09 as the essentials.

01	How the attack economy works Why exposure has little to do with whether anyone singled you out.	• CONTEXT
02	External threat Lookalikes of the platforms you use, and of your own brand — what is aimed at you, and what is simply in circulation.	• FINDINGS
03	Outbound posture DMARC, SPF, CAA, MTA-STS — whether your own domain can be spoofed, hijacked or mis-issued against.	• FINDINGS
04	Full DNS records Every record we captured, with the defensive weaknesses called out inline.	• FINDINGS
05	Infrastructure & routing intelligence The quality of the IP, prefix and ASN hosting you — routing integrity, reputation, co-tenancy.	• FINDINGS
06	Your SaaS platforms The business software your DNS shows you use, grouped by kind, with the evidence and any cloud each one runs on.	• FINDINGS
07	Hidden infrastructure Forgotten subdomains and dormant services — the assets attackers find that you may not know exist.	• FINDINGS
08	Recent changes Changes in the last two months to your email authentication, DNSSEC, mail servers and nameservers, each dated.	• FINDINGS
09	Your minimisation roadmap The fixes sequenced by impact — fortnight, quarter, year — with effort and ownership.	• ACTION
10	IT remediation plan Every fix with its current state and exact step. Detachable, for whoever owns the changes.	• ACTION
11	Glossary & methodology Definitions of every technical term, plus how the evidence was gathered.	• CONTEXT

**How to read this report**

Ten minutes: page 1, sections 02 and 09. **Thirty:** add 03 — your defensive controls. Every section opens in plain English before the technical detail.

SECTION 01

• CONTEXT

How the cyber attack economy works.

Platform impersonation is an industry with business models. How it operates explains why every organization on Microsoft 365 sits in its path.

3rd

If cybercrime were a country, it would be the world's third-largest economy — behind only the United States and China. It is projected to cost the world **\$10.5 trillion in 2025**, roughly **\$29 billion every day**.

Source: Cybersecurity Ventures, 2025 Official Cybercrime Report. Industry context, not a Datazag measurement.

That economy runs on a few repeatable business models. The one that reaches your employees is **mass credential harvesting** — an estimated **80–90% of all platform-impersonation activity** (industry estimate). It is why your exposure has little to do with whether anyone singled you out.

How mass credential harvesting works — “spray and pray”

- 1 Harvest the list.** Corporate addresses bought from breach dumps or scraped from public directories — accumulated by the million, not chosen.
- 2 Blast identical fakes.** Automated frameworks send the same fake Microsoft 365 alert — “your password has expired” — to every address, each pointing at a convincing fake login page.
- 3 Harvest credentials at volume.** If even 1% enter their password, the operator nets thousands of valid logins, then resells them to extortion and ransomware crews.

⚠ **It often takes only one — and you may never know it happened.** A single working credential moves you off the anonymous spray-and-pray list onto a **curated target list**. Because a credential is data, the same access is often **resold to several buyers at once**. And a **captured login is usually silent**: no outage, no alert, and the gap between compromise and discovery is often weeks.

Nobody decided to target [meridianholdings.example](#). They decided to target **everyone who uses Microsoft 365** — and you do. That is the logic of your exposure.

The platforms that put you in the target set — read from your mail and DNS configuration, not guessed. Section 02 shows who is currently imitating them.

Microsoft 365

Works on any office worker, and the credentials unlock email, files and SSO into other tools. The most-impersonated platform in our data.

Okta

Okta credentials ARE the keys — one captured login unlocks every application behind the SSO.

Mailchimp

Unlocks the customer mailing list directly — the fastest path from staff compromise to brand impersonation at scale, sent from your real account.

SECTION 02

FINDINGS

Who is impersonating meridianholdings.example.

Critical-severity impersonation detections from certificate-transparency logs over the last 7 and 30 days — against the platforms meridianholdings.example uses, and the meridianholdings brand itself.

70

CRITICAL PLATFORM IMPERSONATIONS · 30D
· INTERNET-WIDE

17

· 7D

3

PLATFORMS TARGETED

3

OWN-BRAND · 30D

DETECTED PLATFORM STACK strongest signal first

PLATFORM	SIGNAL	CONFIDENCE
Microsoft 365	CORPUS: platform stack detection	indicative
Okta	CORPUS: platform stack detection	indicative
Mailchimp	CORPUS: platform stack detection	indicative

Confidence: confirmed = live MX, CNAME or SPF; indicative = a verification token only (may be stale).

ACTIVE PLATFORM IMPERSONATION last 7 / 30 days

PLATFORM	7D	30D	TREND	SAMPLE DOMAINS
microsoft365	14	41	↑	micros0ft-365-login.example office365-verify.example ms365-secure.example
okta	2	25	↓	okta-sso-login.example okta-verify.example
mailchimp	1	4	→	mailch1mp-campaign.example

Counts are critical-severity detections only — registrable domains imitating the platform itself, seen in certificate transparency logs across the whole internet, each counted once. Lower-severity matches and fuzzy lookalike candidates are left out. These are not domains registered to target meridianholdings.example; they measure how heavily a lure your staff would recognize is being manufactured right now.

BRAND LOOKALIKES typosquats of meridianholdings

3 in 30 days (1 this week): meridianholdings-support.example

Plus 6 lower-confidence typosquat candidate(s): meridian-holdings.example mreidianholdings.example

LOOKALIKE CANDIDATES Lower confidence — fuzzy, not exact matches

microsoft365 ×11 rnicrosoft365.example micr0s0ft-365.example

Fuzzy matches against the platform names above, counted across the internet — not domains registered against meridianholdings.example. Short or dictionary-word brand names can produce false positives — a watchlist, not confirmed activity.

WHAT TO DO from these observations

- 41 critical Microsoft 365 impersonation domains internet-wide (30 days) — Brief staff who use Microsoft 365 on the current impersonation wave (14 critical impersonation domains this week); verify phishing-resistant MFA on the tenant.
- 3 lookalike domains targeting your brand (30 days) — Review the lookalike watchlist above; initiate takedown for any serving content or mail.

Defensive controls — what we can see externally.

Every control here is **directly observable** from DNS, SSL or RDAP — no tenant access required. **Deployed** is credit for work done; **partial** and **missing** each carry the exact fix underneath.

1 of 10 externally verifiable controls deployed · 2 not externally testable 1 DEPLOYED 0 PARTIAL 9 MISSING

DMARC has moved from best practice to operational requirement.
Google and Yahoo have required DMARC for bulk senders since **February 2024**, Microsoft since **May 2025**. Non-compliant senders now face permanent rejections — deliverability problems arrive regardless of the impersonation-defense value.

EMAIL AUTHENTICATION		0 of 5 deployed
DMARC enforcement	MISSING No DMARC TXT record published → Publish DMARC record at <code>_dmarc.meridianholdings.example</code> starting with <code>p=none</code> for reporting. Increasingly required by Google, Yahoo, Microsoft, Apple, and Comcast for bulk-sender deliverability.	HIGH IMPACT
SPF strict mode	MISSING No SPF record → Publish SPF TXT record with <code>-all</code> and all legitimate senders included.	HIGH IMPACT
BIMI	MISSING No BIMI record at <code>default._bimi</code> → Publish BIMI record (requires DMARC at <code>p=quarantine</code> or stronger).	LOW IMPACT
DKIM signing	LIMITED VISIBILITY Limited external visibility — selectors are arbitrary, not enumerable without internal knowledge → Verify internally: Microsoft 365 typically uses <code>selector1</code> and <code>selector2</code>; Google Workspace uses <code>google</code>. Each sending platform has its own selectors; each should be rotated annually.	MEDIUM IMPACT
MTA-STS	MISSING No MTA-STS DNS record and no <code>mta-sts</code> host → Publish MTA-STS DNS TXT and policy file in testing mode initially, then move to enforce.	MEDIUM IMPACT
TLS-RPT	MISSING No TLS-RPT record → Publish a TLS-RPT TXT record pointing to an inbox or aggregator that can receive TLS failure reports.	LOW IMPACT
CERTIFICATE & WEB		1 of 3 deployed
CAA records	MISSING No CAA record → Publish CAA records restricting issuance to the CAs you actually use	MEDIUM IMPACT
security.txt	MISSING No <code>/.well-known/security.txt</code> — researchers have no documented channel to report vulnerabilities → Publish a <code>security.txt</code> file at <code>/.well-known/security.txt</code> on <code>meridianholdings.example</code> with a contact, expires date, and preferred languages.	LOW IMPACT
DNS SECURITY		0 of 1 deployed
DNSSEC	MISSING Domain is not signed → Enable DNSSEC at registrar; publish DS records	MEDIUM IMPACT
DOMAIN REGISTRATION		0 of 1 deployed
Registrar locks	NOT ASSESSED Not assessed. RDAP returned no status	HIGH IMPACT
Abuse contact published	MISSING No abuse contact in RDAP → Verify the registrar has a current abuse contact on file	LOW IMPACT

METHODOLOGY NOTES
SPF doesn't inherit to subdomains. Each sending subdomain needs its own record; the audit above covers the apex only. DMARC does inherit, unless overridden with `sp=`.
DKIM cannot be reliably tested externally. Selectors are arbitrary subdomains chosen by the sending platform, so we cannot enumerate them. We probe known selectors for platforms we recognize — absence there does not confirm DKIM is missing.
What we cannot see externally. MFA, Conditional Access, anti-phishing rules, SIEM and staff training sit inside your tenants. They appear as checklist items on the cover card, not as audited controls.

SECTION 04

• FINDINGS

Every record an attacker can read.

The complete DNS footprint for meridianholdings.example — the records any attacker enumerates first. 3 captured; 3 flagged as weaknesses.

MX**1 WEAKNESS**

(none)

▲ No MX records — the domain is not configured to receive mail

CAA**1 WEAKNESS**

(none)

▲ No CAA record — any certificate authority can issue certificates for this domain

DNSSEC**1 WEAKNESS**

not enabled

▲ DNS responses are not cryptographically signed — exposure to DNS spoofing/cache poisoning

WHY THE FULL RECORD SET MATTERS

Public DNS is the first thing an attacker reads: A/AAAA show where you host, MX and TXT show how you send mail and whether you can be spoofed, NS shows your provider, and missing CAA/DNSSEC shows the soft spots.

SECTION 05

• FINDINGS

The infrastructure your domain is hosted on.

Your domain inherits the reputation of the IP, prefix and ASN hosting it — routing integrity, abuse observed in the Datazag corpus, and whether you share space with known-malicious domains.

HOSTING NETWORK (ASN)

AS64500

Evil Hosting Ltd

COUNTRY

RU

Range reputation:

high (whole network)

ANNOUNCED PREFIX

203.0.113.0/24RPKI **INVALID**

MAILBOX PROVIDER

Inhouse

NAMESERVER PROVIDER

not assessed

HOSTING PROVIDER

not assessed

BGP ROUTING POSTURE

MOAS detection	DETECTED
Prefix churn	42
MANRS member	No
MANRS culprit	No

IP & ASN REPUTATION

0.00 low → 1.00 high

ASN infrastructure risk	0.50
IP direct threat score	0.60
Fast-flux risk	0.70
DGA risk	0.65
Concentration risk	0.75
CertStream hits	3

MALICIOUS CO-TENANCY

30 malicious domains share this asn (64500) — e.g. bad1.example, bad2.example, bad3.example

Datazag corpus reason codes:

HIGH_BGP_CHURN

SOME_NEW_UNMAPPED_CODE

HOW THIS IS ASSESSED

We score every ASN and prefix on abuse observed in the Datazag corpus, RPKI validity, MANRS participation, routing anomalies, and the density of malicious neighbours. Your domain inherits that reputation — clean hosting limits an attacker's options.

SECTION 06

• FINDINGS

The platforms meridianholdings.example runs on.

Business software read from your public DNS. A CNAME shows a platform in use today. An SPF or TXT entry shows it is referenced in DNS, which may be left over from a past contract.

No business-software platforms were identified in this domain's public DNS.

WHAT DNS CAN AND CANNOT SHOW

Some platforms are not reliably visible in DNS: their tenants sit in a URL path or behind the vendor's own domain. For Workday, SAP, ServiceNow, SuccessFactors and Microsoft Dynamics 365, this report says not observable from DNS, not that you do not use them.

SECTION 07

• FINDINGS

The assets attackers find that you may not know exist.

Domain registration, subdomains, dormant services, and certificate hygiene. The foundational facts about your estate — discovered through DNS enumeration, SSL transparency logs, and RDAP. **0 live subdomains observed** for meridianholdings.example.

0

TOTAL SUBDOMAINS

0

HIGH-RISK

0MISSED CERT
RENEWALS**0**

CROSS-DOMAIN SANS



Estate hygiene looks clean. No missed certificate renewals, no high-risk subdomains, and cross-domain SAN exposure is within normal range.

WHAT WE LOOK FOR

Subdomains found via DNS enumeration and certificate transparency, each checked for dangling CNAMEs, takeover-vulnerable platforms, shared cross-domain SAN certificates, and missed auto-renewals.

SECTION 08

• FINDINGS

Changes in the last two months.

What Datazag has observed changing in this domain's DNS: email authentication, DNSSEC, mail servers and nameservers. A change can be planned work or an attacker's edit, so each one is worth confirming.

Registration date not assessed. Change history was not assessed for this report.

Datazag records email-authentication, DNSSEC and mail-server posture daily, and nameservers from 6 October 2026.

SECTION 09

• ACTION

The implementation changes that close the gaps.

The weaknesses you can fix from the outside, sequenced by impact — the DNS, certificate and email-auth controls that govern whether your own domain can be spoofed, hijacked or mis-issued against. Platform phishing is defended inside your tenants, which this report cannot see.

This fortnight**4**

41 critical Microsoft 365 impersonation domains internet-wide (30 days)

Platform · < 1 day

3 lookalike domains targeting your brand (30 days)

Brand · varies

Fast-flux DNS pattern detected (score: 0.70)

Infra · varies

RPKI state INVALID — route hijack exposure

Infra · varies

This quarter**6**

Domain-generation-algorithm pattern (score: 0.65)

Infra · varies

High malicious-neighbour concentration (score: 0.75)

Infra · varies

CertStream threat activity on infrastructure (score: 0.60)

Infra · varies

Dangling CNAME — subdomain-takeover exposure

Infra · varies

Hosting IP carries direct threat signal (score: 0.60)

Infra · varies

Infrastructure serving 3 malicious certificate(s)

Infra · varies

This year**6**

Elevated hosting-network risk (infra score: 0.50)

Infra · varies

High IP churn over 30 days (score: 0.70)

Infra · varies

SPF not strict

Infra · varies

Modern email-security controls absent

Infra · varies

High BGP prefix churn

Infra · varies

Infrastructure signal flagged by the Datazag corpus

Infra · varies

How this prioritises: trusted-platform exposure and sensitive subdomains land in **this fortnight**; outbound posture and brand wiring in **this quarter**; estate-wide hygiene in **this year**.

SECTION 10

• ACTION

Remediation plan — hand this to your team.

Every actionable fix, consolidated and prioritised. Each row is self-contained: what is wrong now, and the exact change to make. Detach this page and hand it to whoever owns DNS, email, and infrastructure.

- | | | | |
|----|---|--|--------------------------|
| 01 | CRITICAL ROUTING SECURITY | RPKI state INVALID — route hijack exposure
Fix: Work with the hosting/network provider to publish a correct ROA for the prefix. | ☐ |
| 02 | HIGH EMAIL AUTHENTICATION | DMARC enforcement
Fix: Publish DMARC record at _dmarc.meridianholdings.example starting with p=none for reporting. Increasingly required by Google, Yahoo, Microsoft, Apple, and Comcast for bulk-sender deliverability. | ☐ |
| 03 | HIGH EMAIL AUTHENTICATION | SPF strict mode
Fix: Publish SPF TXT record with -all and all legitimate senders included. | ☐ |
| 04 | HIGH INFRASTRUCTURE INTELLIGENCE | Fast-flux DNS pattern detected (score: 0.70)
Fix: Investigate whether this domain is under external DNS manipulation. Check for unauthorised NS or glue record changes at your registrar. | ☐ |
| 05 | HIGH INFRASTRUCTURE INTELLIGENCE | Domain-generation-algorithm pattern (score: 0.65)
Fix: Verify domain ownership and registration intent. | ☐ |
| 06 | HIGH INFRASTRUCTURE INTELLIGENCE | High malicious-neighbour concentration (score: 0.75)
Fix: Consider migrating to dedicated infrastructure with a lower-risk hosting provider. Review co-hosted domains. | ☐ |
| 07 | HIGH INFRASTRUCTURE INTELLIGENCE | CertStream threat activity on infrastructure (score: 0.60)
Fix: Investigate co-hosted infrastructure for malicious certificate activity. Consider migrating to dedicated infrastructure. | ☐ |
| 08 | HIGH INFRASTRUCTURE INTELLIGENCE | Dangling CNAME — subdomain-takeover exposure
Fix: Audit all CNAME records and remove any pointing to unregistered or expired targets. | ☐ |
| 09 | HIGH THREAT INTELLIGENCE | Hosting IP carries direct threat signal (score: 0.60)
Fix: Validate the serving IP and migrate off flagged infrastructure. | ☐ |
| 10 | HIGH THREAT INTELLIGENCE | Infrastructure serving 3 malicious certificate(s)
Fix: Investigate co-hosted infrastructure; migrate to dedicated infrastructure if malicious neighbours are confirmed. | ☐ |

SECTION 11

• CONTEXT

Plain-English definitions.

Every technical term used in this report, in one line each. Methodology below.

Trusted platform impersonation

Attackers imitate a platform your staff trust to capture credentials. 85–90% of observed activity.

DMARC

Tells receiving servers what to do with unauthenticated mail claiming to be from you (none / quarantine / reject).

CAA

Restricts which certificate authorities may issue for your domain.

Certificate Transparency

Public logs of every SSL certificate issued; we watch them in real time.

Brand impersonation

Attackers imitate your brand to defraud your customers — lookalikes, typosquats, fraudulent certificates.

SPF

Lists which mail servers may send as your domain.

Dangling CNAME

A subdomain pointing at a deleted service — claimable by an attacker.

Trust Grade

Our A–F grade from a 0–100 composite; higher = more exposed.

Methodology

Data sources. Live DNS at snapshot time; certificate transparency logs; Datazag's certificate-issuance pipeline; RDAP registration data; ASN and BGP observations across 320 million domains, refreshed hourly.

Trusted-platform corpus. The identity platforms most often impersonated in certificate-issuance data — Microsoft 365, Google Workspace, Apple, PayPal, DocuSign, Mailchimp, Cloudflare, and the SaaS long tail.

The 85–90% figure. Of suspicious certificate registrations Datazag observed in April 2026, 85–90% imitated a trusted platform. Refreshed monthly; the range absorbs variance.

Trust Grade. A 0–100 composite (higher = more exposed) mapped to A–F. Driven by platform exposure, brand exposure, outbound posture and infrastructure findings.

Own more domains than this one?

This report covers [meridianholdings.example](#). The Estate Attack Surface Report finds the other domains your organization owns, from a free scope of your estate, and assesses each one at this depth: <https://portal.datazag.com/scope?src=paid-report>